UNIT III

User Authentication.

Introduction

User authentication is the process of verifying the identity of a user who is trying to access a system, application, or service. The goal is to ensure that the person or entity attempting to log in is who they claim to be. This process is critical in securing systems, protecting sensitive data, and ensuring that only authorized users can perform specific actions.

Model for Electronic user authentication /Means of Authentication

An electronic user authentication model is crucial for verifying the identity of a user attempting to access a system. Here's an outline for a comprehensive model based on modern best practices in electronic authentication:

1. Authentication Factors: User authentication can be divided into three primary factors:

- **Something you know (Knowledge-based)**: A password, PIN, or answer to a security question.
- **Something you have (Possession-based)**: A device or token, such as a smart phone, hardware token, or smart card.
- **Something you are (Biometric-based)**: A fingerprint, iris scan, facial recognition, or voice recognition.

Best Practice: Multi-factor Authentication (MFA) combines at least two of these factors, adding extra security layers.

2. Authentication Types

- **Single-factor Authentication (SFA)**: Uses only one factor (e.g., a password).
- **Two-factor Authentication (2FA)**: Uses two factors (e.g., password + SMS code, or password + biometric scan).
- **Multi-factor Authentication (MFA)**: Uses more than two factors (e.g., password + token + fingerprint).

3. Authentication Process: A typical authentication flow could like as follows.

- **User Input**: The user inputs a **username** and **password** (knowledge factor).

- **Credential Verification**: The system verifies the credentials against the database. If the password is correct, move to the next step; if not, access is denied.

1. **Second Factor (if applicable)**:

- **Possession-based**: The system sends a one-time code (OTP) to the user's phone or email.
- **Biometric-based**: The system requests a fingerprint scan or facial recognition.
- **Verification of Second Factor**: The system verifies the one-time code or biometric data.

2. **Access Granted**: If the credentials and any additional factors are verified, the user gains access.

4. Password Management

Passwords are often the weakest link in security. To manage them securely:

- **Strong Password Policies**: Require a mix of upper and lower case letters, numbers, and special characters.
- **Password Hashing**: Use a strong hashing algorithm to store passwords securely.
- **Salt**: Add random data to passwords before hashing to prevent rainbow table attacks.
- **Password Expiration & Rotation**: Regularly expire passwords and encourage users to update them.
- **Password Managers**: Encourage users to use password managers to store and generate secure passwords.

5. Security Considerations

- **Rate Limiting & Lockouts**: To prevent brute-force attacks, implement rate limiting and account lockouts after multiple failed login attempts.
- **Captcha**: Use CAPTCHA systems to prevent automated login attempts.
- **Logging & Monitoring**: Monitor authentication logs for suspicious activity, such as multiple failed login attempts or logins from unusual locations.
- **Secure Communication**: Always use **HTTPS/TLS** to encrypt communication between the client and server.

6. User Education: Users should be educated about:

1) **Phishing Attacks**: Warning them not to share credentials.

2) The Importance of MFA: Encouraging them to enable MFA for an additional layer of security.

3)Secure Password Practices: Set different password to different application (Avoid to use same password to different applications).

Password vulnerabilities

Passwords are one of the most common forms of user authentication, but they have several vulnerabilities that make them susceptible to attacks. Below are some of the most significant vulnerabilities associated with passwords:

1. Weak Passwords: Many users create simple, easy-to-guess passwords like "123456," "password," or their name, making them highly vulnerable to brute-force or dictionary attacks Attackers can easily guess or systematically try combinations of common passwords to gain access.

2. Password Reuse: Users often reuse the same password across multiple accounts (e.g., using the same password for email, social media, and banking accounts). If one account is compromised (via a data breach or phishing), attackers can use the same password to access other accounts, leading to a widespread compromise.

3. Phishing Attacks: Attackers trick users into entering their passwords on fake websites or in response to fraudulent emails or messages (phishing). The attacker captures the password and uses it to access the victim's real accounts, potentially stealing sensitive information.

4. Brute-force Attacks: Attackers systematically try all possible password combinations until they find the correct one. If the password is short or contains only basic characters, it can be guessed relatively quickly. Longer or more complex passwords are harder to guess but still vulnerable to brute-force attacks without protections like rate-limiting or account lockout.

5. Dictionary Attacks: In a dictionary attack, attackers use a precompiled list of common passwords or words (often derived from the dictionary or other common sources) to guess the password. .

6. Password Storage Vulnerabilities:

If passwords are stored insecurely (e.g., in plaintext or with weak encryption), attackers can retrieve them if they gain access to the database. If password storage is compromised, all stored passwords could be exposed, allowing attackers to easily access user accounts. Secure practices like using salted hashes for storage can help mitigate this risk.

7. Social Engineering

Attackers manipulate or deceive users into disclosing their passwords. This could involve pretending to be someone the user trusts, such as a tech support agent or co-worker. The attacker gains access to sensitive information or systems because the user willingly provides their password.

8. Password Cracking Tools

Sophisticated password-cracking tools allow attackers to try millions of password combinations per second, accelerating the process of cracking a password. Weak or vulnerable to being cracked in a relatively short amount of time.

9. Password Sharing

Users sometimes share their passwords with others (e.g., colleagues, family members) or store them insecurely, making them vulnerable to exposure.

Physical Characteristics used in Biometric Applications:

In Biometric Systems, physical characteristics are used to uniquely identify individuals based on their inherent, measurable traits. Some of the most commonly used physical characteristics include:

- **Fingerprint:** The most widely used biometric trait, fingerprint recognition relies on the unique patterns of ridges and valleys on the skin of a person's fingers.
- **Face:** Facial recognition technology analyzes the unique features of a person's face, such as the distance between eyes, nose shape, jawline, and other distinguishing facial features.

- **Iris:** Iris recognition examines the unique patterns in the colored part of the eye (the iris), which is considered one of the most accurate biometric traits.
- **Retina:** Similar to iris recognition, retinal scanning analyzes the pattern of blood vessels in the retina at the back of the eye.
- **Hand Geometry:** Hand geometry recognition analyzes the shape, size, and other features of a person's hand, including the length and width of fingers.
- **Palm Print:** Similar to fingerprints but focusing on the entire palm, palm print recognition analyzes the unique patterns of ridges and lines on the palm of the hand.
- **DNA:** DNA-based biometric systems analyze genetic information, providing an extremely high level of accuracy, though its use in daily biometric systems is less common due to privacy concerns and complexity.
- **Vein Patterns**: Vein pattern recognition, often used in hand or finger vein recognition, analyzes the unique pattern of veins underneath the skin, which is difficult to replicate.
- **Voice:** Voice recognition analyzes unique vocal characteristics such as pitch, tone, and speech patterns to verify identity.

These physical characteristics are analyzed and stored in biometric systems to provide a secure means of authentication and identification. Each has its own level of accuracy, convenience, and security.

Password Selection Strategies:

When choosing a password, it's important to ensure that it's both strong and memorable. Here are some strategies to help you select a secure password:

1. Use a Long Password: Length matters: A longer password is generally more secure. Aim for at least 12-16 characters. Which must be the combination of Uppercase letters (A-Z), Lowercase letters (a-z), Numbers (0-9) and Special characters (e.g., @, $, %, &, *, !)

2. Avoid Common Words and Phrases: Don't use common passwords like "123456", "password", or easily guessable information like your name, birthdates, or simple keyboard patterns.

3. Avoid dictionary words: Passwords based on words in the dictionary can be cracked quickly by attackers using "dictionary attacks."

4. Use a Passphrase: A passphrase can be a sequence of random words or a sentence that's easy for you to remember but hard for others to guess. For example, **"BlueTiger!WandersAtNight"** is strong and memorable.

5. Incorporate Randomness: For maximum security, generate a random password using a password manager or a random password generator tool.

6. Use a Password Manager: Password managers can generate and store strong, unique passwords for each account, reducing the need for you to memorize them.

7. Avoid Reusing Password: Use a unique password for each service to ensure that if one password is compromised, it doesn't affect your other accounts.

8. Consider a Password Strength Checker: Tools like "**HowSecureIsMy Password"** can give you an idea of how long it would take for an attacker to guess your password.

By combining these strategies, you can ensure that your passwords are more secure while still being manageable for your own use.

Important Questions: (Assignment 3)

Q.1 Explain electronic user authentication/means of authentication.

Q.2 what are vulnerabilities of password? Explain in detail.

Q.3 Explain physical characteristics of biometric application.

Q.4 Explain password selection strategies.